UNIVERSIDAD INTERNACIONAL DEL ECUADOR

FUNDAMENTOS DE LA SEGURIDAD DE LOS SISTEMAS INFORMÀTICOS Y DE LA INFORMACIÓN

Proyecto Integrador – Fase 1: Análisis y requisitos de seguridad

Integrantes

Santiago Alejandro Lucina Mena

Pamela Stefania Toapanta Pila

Camila Isabel Paucar Guaranda

Profesor:

JUAN FERNANDO LOPEZ TITO

14 de octubre de 2026

ÍNDICE

1. DESCRIPCIÓN DEL SISTEMA SELECCIONADO 2
2. ACTIVOS A PROTEGER 3
3. AMENAZAS, VULNERABILIDADES Y RIESGOS 5
4. REQUISITOS DE SEGURIDAD Y CRITERIOS DE ACEPTACIÓN 6
5. NECESIDADES DE AUTENTICACIÓN Y AUTORIZACIÓN 8
6. MATRIZ DE TRAZABILIDAD INICIAL 9
NOMBRES Y FIRMAS 10

1. DESCRIPCIÓN DEL SISTEMA SELECCIONADO

La solución propuesta consiste en una plataforma de correo electrónico interno diseñada para facilitar y formalizar la comunicación entre las dos sedes de la organización. El sistema centraliza el intercambio de correspondencia institucional dentro de un canal privado y controlado, reemplazando el uso de plataformas externas e informales para reducir el riesgo de pérdida de información confidencial. Desde una perspectiva de seguridad, la plataforma implementa un control de acceso estricto donde cada usuario debe validar su identidad mediante credenciales y tokens de sesión antes de interactuar con el servicio, todo ello operando sobre una infraestructura de red debidamente segmentada que aísla los recursos importantes y garantiza la trazabilidad e integridad de los mensajes entre ambas sedes.

2. ACTIVOS A PROTEGER

Dentro de nuestra solución existen diversos componentes para su funcionamiento, muchos de los cuales son intangibles como la información y los servicios digitales. Para analizarlos de una buena manera, los activos se clasifican en cuatro categorías principales:

Servicios y Aplicaciones

- **Servidor de Correo Interno en Go (Backend):** Es el eje central del sistema. Procesa el envío, recepción y consulta simultánea de mensajes entre ambas sedes. Si este servicio falla o es alterado, la comunicación oficial de la organización se detiene por completo.
- **Cliente de Correo en Go:** Es el programa instalado en los equipos de los usuarios. Permite a los empleados redactar y consultar mensajes asegurando que las solicitudes viajen completas y sin fugas de datos.
- **Servicio de Autenticación (FastAPI):** Se encarga de comprobar la identidad de los usuarios y emitir los tokens de sesión para navegar en la plataforma. Si este

servicio deja de funcionar, ningún usuario podrá ingresar. Aparte, si es vulnerado, personas externas a la organización podrían acceder sin autorización.

- **Sistema Operativo del Router de Borde (OpenWrt):** Administra la seguridad en la entrada de cada sede, controlando qué tráfico puede entrar o salir mediante reglas de firewall, asignando direcciones IP automáticamente y conectando las redes internas de forma ordenada.

Infraestructura de Red y Equipamiento Físico

- **Routers de Borde OpenWrt (Sedes A y B):** Son las compuertas principales de cada sede. Dirigen el tráfico de datos y garantizan que ambas ubicaciones puedan comunicarse de manera continua a través del enlace inalámbrico compartido mediante enrutamiento dinámico (OSPF).
- **Switches Cisco de Distribución y Acceso:** Dispositivos encargados de interconectar físicamente los equipos de cada sede. Separan a los distintos grupos como usuarios, servidores, invitados y administradores para que no se mezclen, y mantienen conexiones duplicadas seguras para que la red no se caiga si un cable o puerto falla, evitando a su vez bloqueos por tráfico en bucle.
- **Enlace Inalámbrico Inter-Sede (WAN):** Es el canal de comunicación que une a las dos sedes. Su estabilidad y protección contra saturaciones son muy importantes para que los correos viajen entre oficinas sin demoras ni interrupciones.
- **Servidores Físicos:** Equipos físicos dedicados a alojar la base de datos, el servidor de correo en Go y el servicio de autenticación en FastAPI. Su valor radica en mantener estos servicios siempre encendidos y protegidos.

Datos e Información

- **Mensajes y Correspondencia Corporativa:** Contienen instrucciones de trabajo, acuerdos internos y comunicados oficiales. Su importancia radica en evitar que personas no autorizadas lean su contenido o que los mensajes sean modificados indebidamente.

- **Base de Datos y Almacenamiento:** Lugar donde se guardan permanentemente los correos, quién los envió, quién los recibió y su estado de lectura. Garantiza que la empresa no pierda su historial de comunicaciones ante cualquier imprevisto.
- **Registros de Actividad:** Archivos que registran la hora exacta, el usuario y la dirección de red desde donde se realizó cada acción. Son esenciales para saber qué ocurrió ante cualquier incidente de seguridad y para elaborar métricas operativas.

Credenciales y Control de Acceso

- **Tokens Digitales de Sesión:** Pases temporales emitidos tras iniciar sesión exitosamente que se adjuntan a cada acción del correo. Funcionan como una firma digital. Si en algún momento un atacante los intercepta, podría hacerse pasar por un empleado sin necesidad de conocer su clave.
- **Usuarios y Contraseñas:** Datos de acceso individuales que permiten a cada trabajador entrar a su buzón. Si se exponen, se pone en riesgo directo la privacidad de sus mensajes y la de sus compañeros.
- **Credenciales de Administración de Red:** Claves maestras que permiten configurar y gestionar los equipos de red. Si caen en manos indebidas, un atacante obtendría el control total sobre la conectividad, las restricciones y la seguridad de toda la empresa.

3. AMENAZAS, VULNERABILIDADES Y RIESGOS

Situación 1(R0-1): Interceptación y alteración de tráfico en tránsito (Man-in-the-Middle)

- **Activo:** Tokens Criptográficos de Sesión y Mensajería Corporativa en tránsito.
- **Amenaza:** Interceptación pasiva o activa por parte de un atacante situado en el segmento inalámbrico compartido inter-sede o en un segmento de red adyacente.

- **Vulnerabilidad:** Transmisión de solicitudes cliente-servidor mediante canales TCP/HTTP en texto plano sin cifrado en la capa de transporte.
- **Consecuencia / Riesgo:** Captura no autorizada de tokens de sesión activos y lectura de la correspondencia confidencial, permitiendo al atacante retener sesiones válidas y alterar o falsificar el contenido de los correos corporativos antes de que lleguen a su destino.

Situación 2(R0-2): Suplantación de identidad por reutilización y fuga de credenciales de usuario

- **Activo:** Credenciales de Usuarios Institucionales y Bandejas de Correo.
- **Amenaza:** Acceso indebido y suplantación de identidad por parte de personal interno no autorizado o terceros malintencionados. Esto a través de utilizar credenciales compartidas o sesiones abandonadas en equipos de trabajo.
- **Vulnerabilidad:** Ausencia de políticas de expiración o caducidad temporal en los tokens de sesión, falta de bloqueo de pantalla o cierre automático por inactividad en el cliente Go, y uso de contraseñas predecibles sin autenticación multifactor.
- **Consecuencia / Riesgo:** Envío de mensajes fraudulentos o comprometedores en nombre de directivos o personal administrativo, eliminación indebida de correos oficiales y pérdida de confiabilidad en la trazabilidad de los procesos institucionales.

Situación 3(R0-3): Intrusión y compromiso del plano de gestión de red (Acceso Administrativo)

- **Activo:** Credenciales y Acceso Administrativo de Red.
- **Amenaza:** Ataque de fuerza bruta o escalamiento de privilegios dirigido a los servicios de administración remota.
- **Vulnerabilidad:** Falta de restricción de acceso administrativo exclusivamente a la VLAN 99 (Administración), uso de credenciales de baja complejidad y ausencia de listas de control de acceso que bloqueen peticiones desde redes operativas o de invitados.

- **Consecuencia / Riesgo:** Toma de control total de los equipos de borde y conmutación. Un atacante podría alterar las tablas OSPF, inyectar rutas maliciosas, deshabilitar las reglas de firewall o redirigir todo el tráfico hacia servidores externos bajo su control, interrumpiendo por completo la comunicación entre sedes.

4. REQUISITOS DE SEGURIDAD Y CRITERIOS DE ACEPTACIÓN

A partir de los riesgos identificados en la infraestructura y en los servicios de la plataforma de mensajería, se establecen los requisitos de seguridad necesarios para proteger los activos de la organización, junto con los criterios técnicos que permitirán validar su correcto cumplimiento:

Tabla 1

Requisitos de seguridad y criterios de aceptación de la plataforma de correo interno

CÓDIGO	REQUISITO	CRITERIO DE ACEPTACIÓN
RF-SEC-01	El sistema deberá exigir autenticación mediante usuario y contraseña en el servicio FastAPI, emitiendo un token de sesión con tiempo de expiración definido y cerrando la sesión automáticamente por inactividad en el cliente Go.	Un usuario con credenciales válidas recibe un token activo y accede a la plataforma; un usuario con credenciales inválidas, con un token expirado o que supere el tiempo de inactividad en el equipo es rechazado y debe volver a iniciar sesión.
RF-SEC-02	El servidor de correo en Go deberá validar el rol del usuario y su identidad en cada petición para permitir el acceso únicamente a su propio buzón y a las funciones de su área.	Un usuario autenticado solo puede leer, enviar o eliminar mensajes de su propia bandeja; cualquier intento de consultar o alterar correos de otros colaboradores o acceder a funciones de administración es bloqueado por el servidor.
RF-SEC-03	El sistema deberá almacenar las contraseñas aplicando funciones hash	Ninguna contraseña se guarda en texto plano en la

	seguras en la base de datos y cifrar mediante TLS todo el tráfico de correos, credenciales y tokens entre el cliente Go, el servidor Go y FastAPI.	base de datos y, al realizar una captura de paquetes en la red o en el enlace inter-sede, los tokens y el contenido de los mensajes son ilegibles; las peticiones sin cifrar son rechazadas.
RF-SEC-04	Los routers OpenWrt y switches Cisco deberán restringir el acceso administrativo exclusivamente a la VLAN 99 mediante reglas de firewall y listas de control de acceso (ACL), además de autenticar el enrutamiento OSPF entre sedes.	Un administrador desde la VLAN 99 con credenciales válidas puede gestionar los equipos; cualquier intento de acceso administrativo desde las redes de usuarios, servidores o invitados, o anuncios OSPF sin autenticar, son bloqueados.

Nota. Elaboración propia.

5. NECESIDADES DE AUTENTICACIÓN Y AUTORIZACIÓN

Para garantizar la seguridad, el control de acceso y la integridad de la correspondencia interna entre la Sede A y la Sede B, se establecen las siguientes necesidades preliminares:

Tipos de usuarios que utilizarán el sistema:

- **Personal Operativo y de Ventas (Área Operativa):** Empleados encargados de la ejecución de tareas diarias, redacción de correos institucionales, envío de solicitudes y consulta de su respectiva bandeja de salida.
- **Personal Administrativo y de Gestión (Área Administrativa):** Usuarios responsables de la recepción y seguimiento de directrices, consulta de bandejas de entrada, lectura de mensajes con actualización automática a estado "leído" y eliminación lógica de registros institucionales.
- **Personal de Sistemas y Soporte Técnico (Área de Tecnologías de la Información):** Administradores encargados de la supervisión técnica, validación centralizada de sesiones y control general de la plataforma de mensajería entre las sedes.

Recursos o funcionalidades que requerirán autenticación:

- Toda transacción, consulta o envío de datos ejecutada desde la aplicación cliente hacia el servidor central de correos requerirá obligatoriamente una validación previa de identidad por medio de un token de sesión.
- Las acciones de redacción, envío, consulta de bandejas de entrada y salida, lectura con cambio de estado y eliminación de mensajes exigen que el usuario esté debidamente autenticado

Acciones o recursos que no deberían estar disponibles para todos los usuarios:

- El acceso a las bandejas de correo privadas, borradores y correspondencia institucional de otros colaboradores está estrictamente restringido; ningún usuario operativo o administrativo podrá consultar, modificar o eliminar mensajes ajenos.
- Las herramientas de configuración general, gestión de cuentas y control de la plataforma de mensajería están reservadas exclusivamente para el personal autorizado del área de sistemas.

Información que requiere mayor protección:

- **Credenciales de acceso y tokens de sesión:** Las contraseñas corporativas de los usuarios y los tokens de autenticación emitidos por el sistema de seguridad.
- **Cuerpo y metadatos de los mensajes internos:** Contienen información administrativa, directiva e instrucciones operativas sensibles entre las dos oficinas, las cuales no deben ser expuestas ni interceptadas por canales informales o personal no autorizado.

6. MATRIZ DE TRAZABILIDAD INICIAL

Para demostrar que los requisitos de seguridad planteados responden de manera directa a los riesgos y vulnerabilidades identificados en la plataforma de mensajería y su infraestructura, se establece la siguiente matriz de trazabilidad

Tabla 2

Matriz de trazabilidad inicial de riesgos y requisitos de seguridad

RIESGO IDENTIFICADO	REQUISITO ASOCIADO	¿Qué se busca evitar o reducir?
R0-1	RF-SEC-03	Prevenir la captura no autorizada de tokens de sesión activos y la lectura o modificación maliciosa de la correspondencia confidencial durante su paso por la red.
R0-2	RF-SEC-01	Mitigar el riesgo de envío de mensajes fraudulentos o suplantación de personal directivo y administrativo, asegurando que las sesiones inactivas expiren y que nadie acceda a bandejas ajenas.
R0-3	RF-SEC-04	Evitar la toma de control total de los dispositivos de borde y conmutación, la alteración indebida de tablas de enrutamiento OSPF y la desactivación de reglas de seguridad perimetral.

Nota. Elaboración propia.

NOMBRES Y FIRMAS

- Santiago Alejandro Lucina Mena
- Pamela Stefania Toapanta Pila
- Camila Isabel Paucar Guaranda

